

GDPR Compliance Checklist

General Data Protection Regulation (EU) 2016/679

Audit Information

Company Name: _____
Auditor: _____

Date: _____
Version: 2.4 (2026)

1 Lawfulness, Fairness, and Transparency

Ensure all data processing has a valid legal basis.

- ☐ **Consent Forms:** Consent is freely given, specific, informed, and unambiguous. We store proof of consent.
- ☐ **Privacy Policy:** Our privacy notice is written in clear, plain language and is easily accessible on our website.
- ☐ **Legal Basis:** We have documented the legal basis (e.g., Contract, Consent, Legitimate Interest) for each data processing activity.
- ☐ **Data Minimization:** We only collect data that is strictly necessary for the stated purpose.

2 Data Subject Rights

Procedures to handle requests from individuals (Data Subjects).

- ☐ **Right of Access:** We can provide a copy of personal data to a user within 30 days of a request.
- ☐ **Right to Erasure ("Right to be Forgotten"):** We have a mechanism to permanently delete user data upon request, unless legal retention is required.
- ☐ **Data Portability:** We can export user data in a structured, commonly used, machine-readable format (e.g., CSV, JSON).
- ☐ **Objection Handling:** Users can easily opt-out of direct marketing and profiling.

3 Data Security & Accountability

Technical measures and organizational responsibilities.

- ☐ **Encryption & Pseudonymization:** Personal data is encrypted at rest and in transit.
- ☐ **Data Breach Protocol:** We have a procedure to notify the Supervisory Authority within **72 hours** of becoming aware of a breach.
- ☐ **DPIA (Data Protection Impact Assessment):** DPIAs are conducted for high-risk processing activities.
- ☐ **Third-Party Contracts:** Data Processing Agreements (DPAs) are signed with all vendors (e.g., Cloud Providers) handling our data.

4 International Data Transfers

Applicable if data leaves the EEA (European Economic Area).

- ☐ We have identified all data transfers to non-EU countries.
- ☐ We rely on Standard Contractual Clauses (SCCs) or Adequacy Decisions for international transfers.

CRITICAL REMINDER: Fines

Non-compliance can lead to fines of up to **€20 Million** or **4% of global annual turnover**, whichever is higher. See *Fine_Tier_Structure.csv* for details.

Sign-off:

Data Protection Officer (DPO)

CEO / Compliance Lead